

C O U R S E 4 2 0 - 4 C 2 - D W

Implementation & Management of Corporate Cybersecurity Measures

Final Project Brief — Spring 2026

PAIR-BASED · VIRTUALBOX LAB · 16 SESSIONS

30 May → 26 June 2026



Cyber.SoHo Educational Hub

From the Industry to the Classroom



Why This Project Exists

“Can you build, defend, attack, detect, and learn from your own corporate infrastructure — end-to-end — the way a real team does?”

- Integrates seven prior courses into one portfolio.
- Mirrors a real security lifecycle: Build → Harden → Attack → Respond → Improve.
- Pair-work mirrors real team structure; solo scope does not scale to the stages.

KEY TAKEAWAY This is not a lecture-style exam. It is a full security programme compressed into four weeks.



The Seven Integrated Courses



420-1C1

Preventative Monitoring



420-1C2

Threats and Risks



420-2C1

Cyber Defence



420-3C1

Managing Vulnerabilities



420-3C2

Intrusion Tests



420-4C1

Incident Management



COMPL.

Compliance Assessments



420-4C2

Implementation & Mgmt

KEY TAKEAWAY Every stage draws from multiple courses. Siloed answers lose marks.



The Four-Stage Map

Stage	Theme	Due	Weight
1	Know Thy Network	Thu 04 Jun	7%
2	Harden & Secure	Thu 11 Jun	7%
3	Test the Defence	Thu 18 Jun	7%
4	Detect / Respond / Recover / Educate	Tue 23 Jun	7%

Final Document 30% · Presentation 12% · Exam 30%

KEY TAKEAWAY Front-load effort. Stage 1 artifacts feed every later stage.



Evaluation Breakdown

28%

Staged deliverables (4 × 7%)

30%

Final document

12%

Oral presentation

30%

Written exam

Presentation is pre-recorded PowerPoint with narration — each partner owns one half.

KEY TAKEAWAY Exam + Final Document together = 60%. Do not neglect the write-up to chase the lab.



The NordForge Scenario

- Fictional client: NordForge Industries Inc. — Quebec precision-forging manufacturer.
- ~180 employees · 3 sites (Montréal HQ, Trois-Rivières plant, Boston R&D).
- Recently hit by a phishing incident — the reason security investment is on the table.
- Confidential engineering IP and customer contracts at stake.
- Subject to PIPEDA, Quebec Law 25, and Bill C-26 obligations.



Fast facts

Sector: Industrial / manufacturing

Headcount: ~180

Sites: Montréal · Trois-Rivières · Boston

Primary concerns: IP theft, plant-floor availability, customer data

KEY TAKEAWAY Your recommendations must fit a mid-size Canadian manufacturer's resources — not a Fortune 500 budget.



Lab Architecture

- MGMT 10.10.10.0/24 — firewall + switch admin only.
- CORP 10.10.20.0/24 — domain corp.nordforge.local.
- DMZ 10.10.30.0/24 — public-facing services.
- SOC 10.10.40.0/24 — Wazuh + Suricata.
- External NAT 198.51.100.0/24 — attacker foothold.



Perimeter

Canonical: OPNsense

Alternatives: pfSense, IPFire

You may substitute — justify your choice in the Stage 2 report.

KEY TAKEAWAY Segmentation is not decoration. Every VLAN has a defensive purpose.



Stage 1 — Know Thy Network

- 01** Enumerate every asset in the lab.
- 02** Identify threats against those assets (STRIDE).
- 03** Rank risks (NIST SP 800-30).
- 04** Baseline the network (Nmap + Wireshark).
- 05** Deploy monitoring (Wazuh + Suricata).

Maps to: Preventative Monitoring · Threats and Risks · Managing Vulnerabilities

KEY TAKEAWAY You cannot defend what you cannot name.



STRIDE Threat Model

S

Spoofing

Pretending to be someone you aren't

T

Tampering

Altering data or code

R

Repudiation

Denying an action took place

I

Information disclosure

Unauthorised read

D

Denial of service

Unauthorised unavailability

E

Elevation of privilege

Unauthorised admin

KEY TAKEAWAY One STRIDE category per asset at minimum. Blank rows = missing analysis.



Risk Assessment Formula (NIST 800-30)

$$\begin{aligned}\text{Inherent Risk} &= \text{Likelihood} \times \text{Impact} \\ \text{Residual Risk} &= \text{Inherent Risk} - \text{Control Effectiveness}\end{aligned}$$

- Score Likelihood and Impact on a 5 × 5 matrix (1 = rare → 5 = certain).
- Document existing controls explicitly.
- Choose a treatment: Accept · Mitigate · Transfer · Avoid.

KEY TAKEAWAY Every risk must tell a causal story — asset, threat, vulnerability, impact.



Baseline Monitoring Stack

- Wazuh — host-based intrusion detection, log shipping, file-integrity.
- Suricata — network IDS/IPS, packet capture, flow analysis.
- Nmap + Wireshark — periodic active and passive baselining.
- Deploy before Stage 2 opens.
- Validate with a fire drill — trigger a rule, watch the alert land.



SOC VLAN

Isolated from production (10.10.40.0/24).

Receives log shipping + mirror traffic.

Never routes to MGMT.

KEY TAKEAWAY If the alert doesn't show up, you won't see the attack.



Stage 2 — Harden & Secure

- 01** Firewall rule matrix (deny-by-default).
- 02** Host hardening (Linux CIS L1, Windows baseline).
- 03** Active Directory hardening (LAPS, Protected Users, tiering).
- 04** Vulnerability scan + CVSS triage.
- 05** Compliance mapping to laws and frameworks.
- 06** Draft three core policies.

Maps to: Cyber Defence · Managing Vulnerabilities · Compliance

KEY TAKEAWAY Hardening is not a checklist — it's a justified choice.



Firewall Design Principles

- Deny by default, allow by exception.
- Rule order matters — specific before general.
- Every allow cites: source · destination · port · protocol · business reason.
- No any-any rules anywhere.
- Inter-VLAN routing only through the firewall — never through a host.
- Log denies at the perimeter; log everything between VLANs.

KEY TAKEAWAY A rule without a justification is a finding, not a control.



Host Hardening — Linux

- SSH — key-only, non-default port, restricted ciphers, no root login.
- Firewall — UFW active, default deny inbound.
- Authentication — pwquality 14+ chars, pam_faillock lockout.
- Patching — unattended-upgrades for security updates.
- Auditing — auditd for syscall + file events.



Start from

CIS Benchmark — Level 1

Ubuntu 22.04 / 24.04

Idempotent scripts only — if you cannot re-run it, it is not a baseline.

KEY TAKEAWAY Idempotent scripts. If you can't re-run it safely, it's not a baseline.



Host Hardening — Windows

- SMBv1 — disabled everywhere (client and server).
- LM / NTLMv1 — blocked; NTLMv2 only.
- Anonymous enumeration — restricted.
- UAC — at highest default-interactive setting.
- PowerShell logging — script block + transcription enabled.
- AppLocker — at minimum, audit mode.

KEY TAKEAWAY If WannaCry-class malware could still spread, the baseline failed.



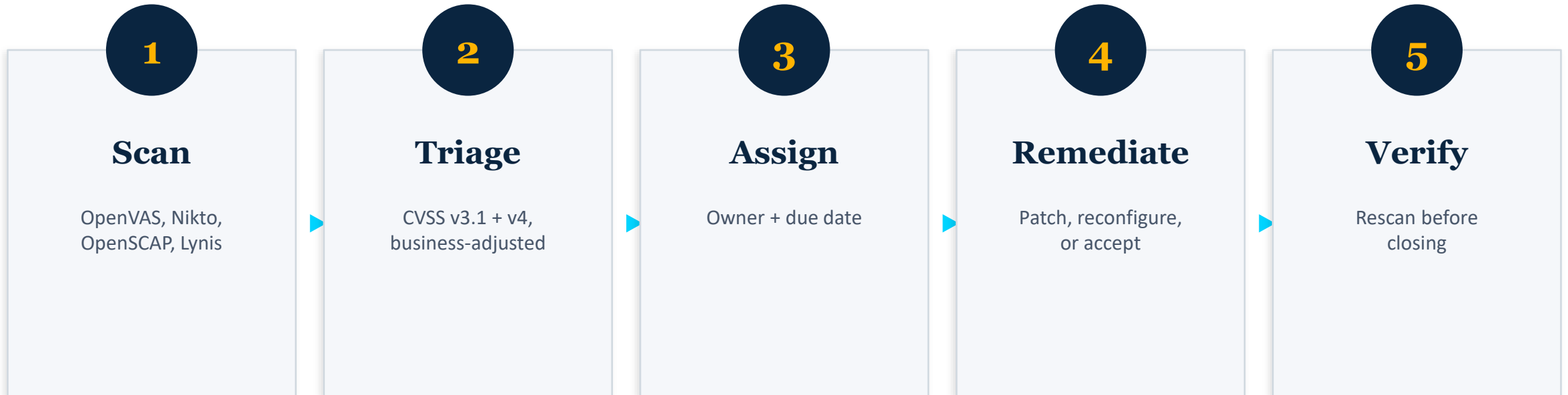
Active Directory Hardening

- Tier-0 / 1 / 2 admin model — no credential crossing tiers.
- LAPS — unique local admin password per host.
- Protected Users — all interactive DA accounts.
- krbtgt password — rotate annually; twice if compromise suspected.
- gMSA for service accounts where supported.
- Kill unconstrained delegation on non-DCs.

KEY TAKEAWAY AD compromise = full environment compromise. Treat accordingly.



Vulnerability Management Flow



KEY TAKEAWAY A CVSS score alone is not a priority. Business context owns the final call.



Compliance Frameworks Mapped

CA	PIPEDA	Canadian federal privacy — 10 fair-information principles
QC	Quebec Law 25	Enhanced privacy + mandatory breach reporting
CA	Bill C-26 / CCSPA	Critical infrastructure cyber obligations
US	NIST SP 800-53 Rev. 5	Technical control catalogue
INT	ISO/IEC 27001:2022	Information security management system

KEY TAKEAWAY Map each control you deploy to at least one framework statement.



Stage 3 — Test the Defence

- 01 Signed Rules of Engagement (RoE).
- 02 OPSEC-clean testing posture.
- 03 Passive + active recon (PTES phases).
- 04 Three mandatory exploits: network service, web app, AD.
- 05 IDS / firewall evasion attempt.
- 06 Full pentest report deliverable.

Maps to: Intrusion Tests

KEY TAKEAWAY No RoE signature → no testing. Period.



PTES Methodology — Seven Phases



KEY TAKEAWAY Each phase has evidence. No evidence = the phase didn't happen.



Mandatory Exploit Categories

Domain	Lab target	Example technique
Network service	Metasploitable 2	Unauthenticated service exploit
Web application	DVWA or Juice Shop	OWASP Top 10 chain (SQLi, XSS, IDOR, SSRF...)
Active Directory	corp.nordforge.local	AS-REP / Kerberoasting

One demonstration of each is the floor, not the ceiling.

KEY TAKEAWAY Chain the attacks when possible — demonstrate impact, not just access.



Active Directory Attacks to Demonstrate

- AS-REP Roasting — accounts without Kerberos pre-auth; offline crack.
- Kerberoasting — request TGS for an SPN account; offline crack.
- Pass-the-Hash — reuse NTLM hash without knowing the password.
- BloodHound — map attack paths to Domain Admin.
- Every attack you demonstrate must have a documented detection by Stage 4.

KEY TAKEAWAY Offensive knowledge is for defensive design — not for showing off.



IDS Evasion — The Honest Attempt

- Timing — slow scans, burst control.
- Fragmentation + decoy sources.
- Payload encoding — base64 PowerShell, XOR.
- Living-off-the-land binaries (LOLBins).
- Document what detected you and what did not — feeds Stage 4 improvements.

KEY TAKEAWAY Evasion is a teaching moment, not a flex. Cover your detections.



Pentest Report Structure

1

Executive summary

1–2 pages, non-technical

2

Technical findings

CVSS, reproduction, evidence, fix

3

Attack narrative

The story, not the tool list

4

Appendices

Raw output, IOCs, versions

Delivered within 5 business days of engagement close.

KEY TAKEAWAY The report is the product. Tools are the commodity.



Stage 4 — Detect, Respond, Recover, Educate

- 01** Simulate IR from Stage 3 artifacts.
- 02** Forensic collection with chain of custody.
- 03** Root-cause + MITRE ATT&CK mapping.
- 04** Three playbooks (phishing · ransomware · web).
- 05** Awareness campaign (poster · handbook · training · KPIs).
- 06** Final IH&R plan v1.0.

Maps to: Incident Management

KEY TAKEAWAY Prevention fails; response is the differentiator.



IH&R Lifecycle (NIST SP 800-61)



→ feeds back to Preparation

Every incident must produce a written timeline and an after-action report.

KEY TAKEAWAY Skip lessons-learned and you guarantee you'll relive the incident.



Chain of Custody Essentials

- Every item has a unique identifier.
- SHA-256 hash recorded before any transfer.
- Every handoff is signed by both parties.
- Analysis on working copies — never the original.
- Retention: 7 years default, longer if legally required.



Break the chain =

Hash mismatch, missing signature, unrecorded copy, or analysis on the original — any one of these can make the evidence inadmissible.

KEY TAKEAWAY If the hash changes or the log is incomplete, the evidence is gone.



Three Playbooks You Deliver



Phishing

Triage, scope, contain, eradicate, communicate.



Ransomware

Assume double-extortion. Do not power off. Consult sanctions before any payment decision.



Web App

Log preservation, WAF containment, secret rotation, session invalidation.

Each playbook: trigger · severity · step-by-step actions · who owns what.

KEY TAKEAWAY Playbooks are muscle memory. Rehearse quarterly or they atrophy.



MITRE ATT&CK Integration

- Every Stage 3 attack step → mapped to an ATT&CK technique ID.
- Every detection in Stage 4 → mapped to the same technique.
- Gaps between attack and detection → improvement backlog.
- Framework pages: attack.mitre.org



Why it works

A common language across offensive and defensive teams.
Converts ambiguous observations into shared, measurable findings.

KEY TAKEAWAY ATT&CK turns "we saw something" into "we saw T1558.003 and blocked it."



Awareness Campaign Deliverables

- Poster / infographic — one-page visual.
- User handbook — two pages, plain-language.
- Training outline — 15 minutes, measurable objectives.
- KPIs — click rate, credential-submission rate, report rate, time-to-first-report.



$\geq 25\%$

REPORT RATE @ 12 MONTHS

KEY TAKEAWAY Without a report-rate target, awareness is theatre.



Required Policies

- Access Control Policy
- Acceptable Use Policy
- Incident Response Plan
- Rules of Engagement (signed)
- Chain of Custody Form
- Three Playbooks (phishing · ransomware · web)
- All aligned to NIST 800-53, ISO 27001:2022, PIPEDA.

KEY TAKEAWAY Templates are a starting point — not a submission.



Alternative Tools Policy

- Replace any canonical tool (OPNsense, Wazuh, OpenVAS, Burp, Metasploit, Impacket) with an equivalent.
- Submit: rationale · functional-equivalence table · working code or config.
- Marks rewarded for reasoned substitution.
- Marks penalised for random swaps.

KEY TAKEAWAY The tool is the means. The outcome is the mark.



The Final Document

- Professional writing — no AI-detection triggers.
- Self-generated diagrams and tables.
- Full evidence trail — screenshots, logs, hashes.
- Reproducibility — everything re-runnable from the repo.
- Integration across the seven courses — one coherent narrative.



Weight

30%

OF THE FINAL GRADE

KEY TAKEAWAY The document is the portfolio artifact. It outlives the course.



The Presentation

- 20 minutes pre-recorded PowerPoint narration + 10 minutes live Q&A.
- Each partner owns one half (~10 minutes).
- Partner A — defensive half. Partner B — offensive + response half.
- Screenshots from your lab only — no stock images.
- Test the audio. Speak slowly. 150 words/minute is about right.

KEY TAKEAWAY Reading the slide is the surest way to lose marks.



Ethics and Scope



Out-of-scope testing is a criminal offence

under s. 342.1 of the Criminal Code of Canada.

- Authorised lab only. Always.
- Sign the RoE. Keep the scan traffic inside the lab VLANs.
- Every tool runs through VirusTotal before execution.

KEY TAKEAWAY Respect the tools. Respect the profession. Respect each other. Build something real.



Where to Find Help

NIST Publications

csrc.nist.gov/publications

MITRE ATT&CK

attack.mitre.org

OWASP

owasp.org

OPC — Canada

priv.gc.ca

CCCS

cyber.gc.ca

CIS Benchmarks

cisecurity.org/cis-benchmarks

KEY TAKEAWAY Primary sources beat blog posts. Cite the standard, not the SEO.



Final Checklist Before Stage 1

- ☒ Pair formed and confirmed with the instructor.
- ☒ VirtualBox installed and snapshotted.
- ☒ Five VLAN networks created.
- ☒ VMs downloaded from official sources.
- ☒ Hashes verified against vendor checksums.
- ☒ Repository initialised (git + README).
- ☒ Calendar blocks reserved for every Stage due date.

KEY TAKEAWAY Preparation is the cheapest phase. Skip it and every later stage costs more.

BUILD SOMETHING REAL

Four stages. Seven courses. One narrative.



“From the Industry to the Classroom — Building the IT's Future, Today and Together!”



© 2026 Cyber.SoHo Educational Hub · 420-4C2-DW